

Falconi Incident Report Form

Executive Summary

On 3 May 2024 @ 04:12 UTC-5 an external adversary successfully brute-forced Falconi's public FTP backup server. Within minutes, the attacker downloaded a PDF and text files, both of which contained an internal SSH password and the locations of Falconi's long-term S3 archives. As soon as the adversary was detected, the IR Team immediately isolated and disabled the FTP and set up new countermeasures to bolster security. Stakeholders and the legal department were immediately contacted to make them both aware of the situation as well as to formulate responses to the exposed information.

Incident Details

- Incident ID:
 - FAC-IR-2024-0503
- Date/Time Detected:
 - 5 May 2024 (PCAP analysis kick-off)
- Reported By:
 - SOC analyst after extortion notice
- Detection Method:
 - Manual PCAP review;
 - Wireshark filter ip.src==15.206.185.207 && ftp
- System(s) Affected:
 - Backup FTP server (vsFTPd 3.0.5) plus linked S3 cold/warm storage buckets
- Incident Type:
 - Data breach / Unauthorized access / Credential exposure
- Severity Level:



- 3 (Targeted attack; limited system compromise)

Description of the Incident

In the pre-dawn hours of 3 May 2024 (04 : 12 : 54 UTC-5), Falconi's Internet-facing backup server running vsFTPD 3.0.5 was quietly compromised.

A remote attacker at 15.206.185.207 succeeded in a brute-force campaign, logging in with the weak credentials `falconi-ftp : ftprocks69$`, immediately gaining interactive control of the FTP service.

Reconstructed attack timeline (from packet capture & server logs):

1. Initial foothold (04 : 12 : 54) – The attacker's successful USER/PASS sequence returns "230 Login successful", confirming access.
2. Environment reconnaissance (≈ 04 : 13-04 : 14) – Standard FTP queries—SYST, FEAT, LIST, NLST—enumerate operating-system details and directory contents, while repeated EPSV commands shift the session into passive mode to evade active connection alerts.
3. Targeted exfiltration begins (04 : 14 : 26) – The attacker issues RETR Maintenance-Notice.pdf; the server responds "226 Transfer complete" after sending the 27.8 KB document.
4. Second file pulled (04 : 14 : 38) – RETR s3_buckets.txt follows, leaking 268 bytes of critical cloud-storage pointers.
5. Metadata confirmation (immediately after downloads) – SIZE and MDTM commands validate byte counts and last-modified stamps for both stolen files—useful for integrity checks before larger-scale theft.
6. Attempted persistence (≈ 04 : 15) – A STOR /home/cyberjunkieX0X/HACKED.txt upload is blocked with "550 Permission denied," hinting at plans to plant a backdoor or marker but foiled by directory permissions.

Why those two files mattered:



- Maintenance-Notice.pdf contained a temporary SSH credential (B@ckup2024!) and a scheduled maintenance window, effectively handing the attacker a skeleton key and a low-visibility time slot for deeper intrusion.
- s3_buckets.txt listed URLs for Falconi's 2023 cold-storage and 2022 warm-storage archives, plus internal contacts, sketching a roadmap to long-term data stores.

Follow-on impact (post-FTP):

Leveraging the exposed SSH password and bucket locations, the attacker pivoted into backup infrastructure in the days that followed, siphoning ≈ 20 GB of archival data before issuing an extortion demand.

Kill-chain view:

Recon → Exploitation (brute-force) → Credential Access → Privilege Escalation (via SSH) → Lateral Movement → Data Exfiltration (~20 GB) → (Attempted) Persistence.

Indicators of Compromise

- Attacker IP : 15.206.185.207 (Mumbai)
- Compromised Service : vsFTPD 3.0.5 (UNIX)
- Stolen Credentials : falconi-ftp / ftprocks69\$, SSH B@ckup2024!
- Exfiltrated Files : Maintenance-Notice.pdf, s3_buckets.txt
- Targeted S3 Buckets : 2023-coldstorage, 2022-warmstor

Impact Assessment

Data Compromised:

- Internal maintenance procedures, including operational scheduling and access workflows



- Backup infrastructure credentials, including plaintext SSH password from Maintenance-Notice.pdf
- S3 archive URLs (2023-coldstorage, 2022-warmstor) and associated metadata
- Select internal employee emails, increasing phishing/social engineering risk
- No direct customer data confirmed exposed, but internal pathways were revealed

Systems Outage / Downtime:

- No production downtime reported
- Backup environment temporarily isolated during containment and investigation
- Account resets and infrastructure hardening introduced brief workflow delays for IT staff

Operational Gaps:

- Brute force login attempts went unchallenged; The attacker made 8 incorrect FTP login attempts before success
- Lack of lockout or rate-limiting controls allowed persistence until credentials were guessed

Business Operations Affected:

- Regulatory exposure due to unmonitored long-term data storage in public-facing S3 buckets
- Extortion threat based on potential public release of internal archive contents
- Resource diversion across IT, legal, and compliance teams for incident response
- Increased internal scrutiny around documentation hygiene and access control

Users Impacted:

- Backup operations team credentials and processes directly affected
- Broader IT staff involved in remediation and access management
- Potential future exposure for employees whose data resides in archived files



- Increased phishing risk for staff whose emails were found in compromised documents

Mitigation & Containment Steps

1. Disabled weak/anonymous FTP; enabled account lockouts and enforced strong passwords.
2. Rotated all exposed credentials and implemented MFA on S3 and backup hosts.
3. Block-listed attacker IP range; deployed WAF rules for brute-force throttling.
4. Captured full forensic images and S3 access logs; preserved evidence chain.
5. Coordinated disclosure plan with Legal & PR per Falconi IR procedures.

Lessons Learned & Protection

1. Don't let "cold" data become a soft spot. The compromise of the FTP server ultimately led to access of older S3 buckets such as 2023-coldstorage and 2022-warmstor, which were still online and accessible without proper monitoring. While intended for archival use, these buckets contained data valuable enough to be extorted. Long-term storage must never be treated as an afterthought. Audit and secure aging cloud assets with the same vigilance as live infrastructure.
2. Never include plaintext credentials in internal documents. The attacker gained privileged access after downloading Maintenance-Notice.pdf from the FTP server. The document contained the backup server's SSH password in plaintext (B@ckup2024!). No document, especially one stored on a shared server, should ever include raw credentials. Secrets should be stored securely, passed via vault tools or secure credential managers, and rotated frequently.



3. Internet-facing services require guardrails. In this case, the attacker attempted 8 incorrect FTP logins before succeeding, and nothing stopped them. The lack of rate limiting or lockout controls allowed the brute force to continue unchecked. All exposed services should enforce lockout thresholds, password complexity, and preferably multifactor authentication. Even basic automation could have prevented access.
4. Backup infrastructure must be logically and physically isolated. The attacker pivoted from the FTP server to backup systems using a shared password and overlapping network access. Backup systems must sit behind strict network ACLs, require MFA, and be auditable independently. Treat backup environments as sensitive production systems, not side closets.
5. Monitor for silent exfiltration techniques. Large outbound transfers over passive FTP were not flagged until after the damage was done. Instrument data-loss detection mechanisms, monitor for anomalous outbound traffic, and treat passive-mode FTP as high-risk or deprecated.
6. Assume any internal document can leak. From a threat model perspective, every document should be treated as potentially public. Internal files often carry too much trust. Adopt a “need-to-know” model, apply watermarks, track access, and train staff to avoid embedding sensitive info in shared content.

Supporting Attachments



No.	ftp ftp-data	Source	Destination	Protocol	Length	Info
69	21.224876	172.31.45.144	15.206.185.207	FTP	86	Response: 220 (vsFTPd 3.0.5)
72	21.226368	172.31.45.144	15.206.185.207	FTP	86	Response: 220 (vsFTPd 3.0.5)
74	21.227176	172.31.45.144	15.206.185.207	FTP	86	Response: 220 (vsFTPd 3.0.5)
75	21.227468	172.31.45.144	15.206.185.207	FTP	86	Response: 220 (vsFTPd 3.0.5)
78	21.228601	172.31.45.144	15.206.185.207	FTP	86	Response: 220 (vsFTPd 3.0.5)
79	21.228898	172.31.45.144	15.206.185.207	FTP	86	Response: 220 (vsFTPd 3.0.5)
80	21.229188	172.31.45.144	15.206.185.207	FTP	86	Response: 220 (vsFTPd 3.0.5)
82	21.229486	172.31.45.144	15.206.185.207	FTP	86	Response: 220 (vsFTPd 3.0.5)
84	21.229775	172.31.45.144	15.206.185.207	FTP	86	Response: 220 (vsFTPd 3.0.5)
87	21.230342	172.31.45.144	15.206.185.207	FTP	86	Response: 220 (vsFTPd 3.0.5)
89	21.230664	172.31.45.144	15.206.185.207	FTP	86	Response: 220 (vsFTPd 3.0.5)
90	21.230937	172.31.45.144	15.206.185.207	FTP	86	Response: 220 (vsFTPd 3.0.5)
92	21.231249	172.31.45.144	15.206.185.207	FTP	86	Response: 220 (vsFTPd 3.0.5)
96	21.232586	172.31.45.144	15.206.185.207	FTP	86	Response: 220 (vsFTPd 3.0.5)

Figure 1 - IP 15.206.185.207 attempted multiple FTP brute-force login attempts before succeeding after using USER forela-ftp and PASS ftpprocks69\$. The successful log-on occurred at 04:12:54 on May 3rd, 2024.

No.	Time	Source	Destination	Protocol	Length	Info
100	2024-05-03 04:12:54.654978	15.206.185.207	172.31.45.144	FTP	78	Request: USER admin
102	2024-05-03 04:12:54.655031	15.206.185.207	172.31.45.144	FTP	78	Request: USER admin
103	2024-05-03 04:12:54.655031	15.206.185.207	172.31.45.144	FTP	78	Request: USER admin
106	2024-05-03 04:12:54.655066	15.206.185.207	172.31.45.144	FTP	78	Request: USER admin
108	2024-05-03 04:12:54.655125	15.206.185.207	172.31.45.144	FTP	78	Request: USER admin
111	2024-05-03 04:12:54.655215	15.206.185.207	172.31.45.144	FTP	80	Request: USER backup
113	2024-05-03 04:12:54.655233	15.206.185.207	172.31.45.144	FTP	83	Request: USER svcaccount
121	2024-05-03 04:12:54.660157	15.206.185.207	172.31.45.144	FTP	80	Request: USER ftpuser
122	2024-05-03 04:12:54.660157	15.206.185.207	172.31.45.144	FTP	80	Request: USER backup
123	2024-05-03 04:12:54.660157	15.206.185.207	172.31.45.144	FTP	80	Request: USER backup
124	2024-05-03 04:12:54.660157	15.206.185.207	172.31.45.144	FTP	83	Request: USER svcaccount
125	2024-05-03 04:12:54.660157	15.206.185.207	172.31.45.144	FTP	80	Request: USER backup
126	2024-05-03 04:12:54.660157	15.206.185.207	172.31.45.144	FTP	80	Request: USER backup
127	2024-05-03 04:12:54.660157	15.206.185.207	172.31.45.144	FTP	83	Request: USER svcaccount
128	2024-05-03 04:12:54.660157	15.206.185.207	172.31.45.144	FTP	83	Request: USER svcaccount
137	2024-05-03 04:12:54.660227	15.206.185.207	172.31.45.144	FTP	83	Request: USER svcaccount
164	2024-05-03 04:12:54.761216	15.206.185.207	172.31.45.144	FTP	84	Request: PASS ftpprocks69\$
165	2024-05-03 04:12:54.761217	15.206.185.207	172.31.45.144	FTP	91	Request: PASS alonzo.spire!rocks
166	2024-05-03 04:12:54.761217	15.206.185.207	172.31.45.144	FTP	81	Request: PASS 69696969
167	2024-05-03 04:12:54.761254	15.206.185.207	172.31.45.144	FTP	84	Request: PASS ftpprocks69\$
168	2024-05-03 04:12:54.761306	15.206.185.207	172.31.45.144	FTP	81	Request: PASS password
169	2024-05-03 04:12:54.761349	15.206.185.207	172.31.45.144	FTP	84	Request: PASS password123
170	2024-05-03 04:12:54.761388	15.206.185.207	172.31.45.144	FTP	91	Request: PASS alonzo.spire!rocks
171	2024-05-03 04:12:54.761469	15.206.185.207	172.31.45.144	FTP	91	Request: PASS alonzo.spire!rocks
172	2024-05-03 04:12:54.761511	15.206.185.207	172.31.45.144	FTP	81	Request: PASS password
173	2024-05-03 04:12:54.761555	15.206.185.207	172.31.45.144	FTP	81	Request: PASS password
174	2024-05-03 04:12:54.761597	15.206.185.207	172.31.45.144	FTP	84	Request: PASS password123
175	2024-05-03 04:12:54.761646	15.206.185.207	172.31.45.144	FTP	81	Request: PASS 69696969
176	2024-05-03 04:12:54.761716	15.206.185.207	172.31.45.144	FTP	81	Request: PASS password
177	2024-05-03 04:12:54.761763	15.206.185.207	172.31.45.144	FTP	84	Request: PASS ftpprocks69\$
178	2024-05-03 04:12:54.761803	15.206.185.207	172.31.45.144	FTP	84	Request: PASS password123
179	2024-05-03 04:12:54.761853	15.206.185.207	172.31.45.144	FTP	81	Request: PASS 69696969
206	2024-05-03 04:12:55.863165	15.206.185.207	172.31.45.144	FTP	80	Request: USER ftpuser

Figure 2 - Once this suspicious log-on was detected, the IR team, used Wireshark to filter out all traffic within the network. The attacker's ip was used to filter information out, 'ip.src == 15.206.185.207 and ftp,' to provide a clearer visual of the attacker's FTP session from start to finish.

308	2024-05-03	04:12:57.650193	15.206.185.207	172.31.45.144	FTP	91 Request: PASS alonzo.spire!rocks
399	2024-05-03	04:14:10.092755	15.206.185.207	172.31.45.144	FTP	83 Request: USER forola-ftp
407	2024-05-03	04:14:15.554506	15.206.185.207	172.31.45.144	FTP	84 Request: PASS ftprocks69\$
411	2024-05-03	04:14:15.605045	15.206.185.207	172.31.45.144	FTP	72 Request: SYST
414	2024-05-03	04:14:15.606799	15.206.185.207	172.31.45.144	FTP	72 Request: FEAT
421	2024-05-03	04:14:18.403741	15.206.185.207	172.31.45.144	FTP	72 Request: EPSV
426	2024-05-03	04:14:18.405493	15.206.185.207	172.31.45.144	FTP	72 Request: LIST
439	2024-05-03	04:14:25.990713	15.206.185.207	172.31.45.144	FTP	72 Request: EPSV
444	2024-05-03	04:14:25.992486	15.206.185.207	172.31.45.144	FTP	72 Request: NLST
453	2024-05-03	04:14:26.781964	15.206.185.207	172.31.45.144	FTP	74 Request: TYPE I
455	2024-05-03	04:14:26.782961	15.206.185.207	172.31.45.144	FTP	95 Request: SIZE Maintenance-Notice.pdf
457	2024-05-03	04:14:26.783849	15.206.185.207	172.31.45.144	FTP	72 Request: EPSV
462	2024-05-03	04:14:26.785549	15.206.185.207	172.31.45.144	FTP	95 Request: RETR Maintenance-Notice.pdf
479	2024-05-03	04:14:26.789175	15.206.185.207	172.31.45.144	FTP	95 Request: MDTM Maintenance-Notice.pdf
484	2024-05-03	04:14:30.972126	15.206.185.207	172.31.45.144	FTP	87 Request: SIZE s3_buckets.txt
487	2024-05-03	04:14:30.973027	15.206.185.207	172.31.45.144	FTP	72 Request: EPSV
492	2024-05-03	04:14:30.974808	15.206.185.207	172.31.45.144	FTP	87 Request: RETR s3_buckets.txt

458	113.689960	172.31.45.144	15.206.185.207	FTP	113 Response: 229 Entering Extended Passive Mode (9759)
462	113.693354	15.206.185.207	172.31.45.144	FTP	95 Request: RETR Maintenance-Notice.pdf
463	113.691701	172.31.45.144	15.206.185.207	FTP	149 Response: 150 Opening EPSV mode data connection for Maintenance-Notice.pdf (27055 bytes).
479	113.695100	15.206.185.207	172.31.45.144	FTP	95 Request: MDTM Maintenance-Notice.pdf
480	113.695109	172.31.45.144	15.206.185.207	FTP	80 Response: 211 20140503043029
484	117.879111	15.206.185.207	172.31.45.144	FTP	87 Request: SIZE s3_buckets.txt
485	117.878212	172.31.45.144	15.206.185.207	FTP	75 Response: 213 208
487	117.879012	15.206.185.207	172.31.45.144	FTP	72 Request: EPSV
488	117.879116	172.31.45.144	15.206.185.207	FTP	114 Response: 229 Entering Extended Passive Mode (23598)
492	117.880979	15.206.185.207	172.31.45.144	FTP	87 Request: RETR s3_buckets.txt
493	117.880939	172.31.45.144	15.206.185.207	FTP	139 Response: 150 Opening EPSV mode data connection for s3_buckets.txt (208 bytes).
499	117.882895	172.31.45.144	15.206.185.207	FTP	80 Response: 226 Transfer complete.

Figure 3 - The attacker proceeded to download two files using the FTP RETR command, which downloads files in FTP. The Maintenance-Notice.pdf was successfully downloaded at 04:14:26, and the s3_buckets.txt file was downloaded at 04:14:38. Server responded with a '226 Transfer Complete,' confirming both files were successfully retrieved.

455	2024-05-03	04:14:26.782961	15.206.185.207	172.31.45.144	FTP	95 Request: SIZE Maintenance-Notice.pdf
457	2024-05-03	04:14:26.783849	15.206.185.207	172.31.45.144	FTP	72 Request: EPSV
462	2024-05-03	04:14:26.785549	15.206.185.207	172.31.45.144	FTP	95 Request: RETR Maintenance-Notice.pdf
479	2024-05-03	04:14:26.789175	15.206.185.207	172.31.45.144	FTP	95 Request: MDTM Maintenance-Notice.pdf
484	2024-05-03	04:14:30.972126	15.206.185.207	172.31.45.144	FTP	87 Request: SIZE s3_buckets.txt
487	2024-05-03	04:14:30.973027	15.206.185.207	172.31.45.144	FTP	72 Request: EPSV
492	2024-05-03	04:14:30.974808	15.206.185.207	172.31.45.144	FTP	87 Request: RETR s3_buckets.txt

Figure 4 - During retrieval of both files, attacker used multiple FTP commands to confirm files and avoid detection. The FTP commands that were used were SIZE (to get byte size of each file), MDTM (time stamp for any modifications done to either file), and EPSV or Extended Passive Mode (which bypasses active monitoring and firewalls).


```

EPSV
229 Entering Extended Passive Mode (|||15028|)
STOR /home/cyberjunkiex0X/HACKED.txt
550 Permission denied.
QUIT
221 Goodbye.

```

Figure 5 - Attacker proceeded to attempt an upload of file HACKED.txt using the FTP STOR command, but they were blocked with 550 Permission denied. The most likely objective was to create a backdoor which the attacker could use for future attacks, but the FTP server denied that access due to insufficient permissions.

Maintenance Window:

The maintenance is scheduled to take place this Saturday 27 april 2024, starting at 2:00 AM and is expected to conclude by 5:00 AM. During this period, access to backup servers will be temporarily unavailable.

Purpose:

The objective of this maintenance is to implement the latest security patches, perform system upgrades, and conduct a thorough check of the backup systems to ensure that our data recovery processes remain robust and efficient.

Impact:

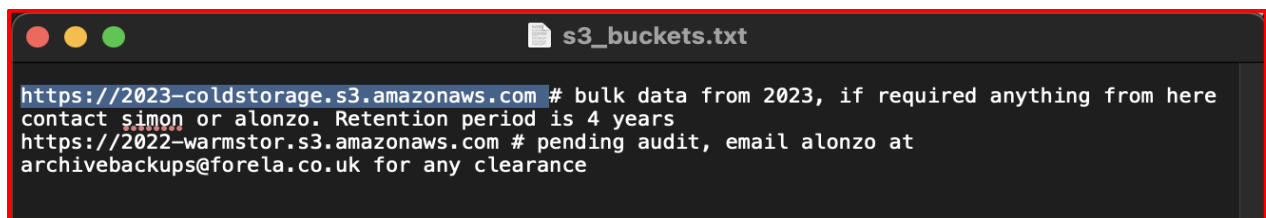
Please expect intermittent or no access to the backup servers during the maintenance window. We advise you to complete any critical work that requires access to these servers ahead of time to avoid any inconvenience.

Contingency Plan:

In the unlikely event of an extended outage, we have a contingent operational plan in place to minimize the impact on our services. We will keep you updated on the progress through our usual communication channels.

For team members requiring urgent access to the backup SSH servers during the maintenance period, you can use the temporary password "***B@ckup2024!***" - kindly ensure this information is handled securely and do not share it outside of our team.

Figure 6 - The attacker proceeded to extract the contents found within the Maintenance-Notice.pdf file. This extraction revealed internal SSH credentials (The temporary password for SSH servers: 'B@ckup2024!') as well as a scheduled down time (Saturday April 27,2024 – 2:00 AM to 5:00 AM). Not only was sensitive information released, but a perfect time window was also provided for lateral movement via SSH.



```
s3_buckets.txt
https://2023-coldstorage.s3.amazonaws.com # bulk data from 2023, if required anything from here
contact Simon or Alonzo. Retention period is 4 years
https://2022-warmstor.s3.amazonaws.com # pending audit, email Alonzo at
archivebackups@forela.co.uk for any clearance
```

Figure 7 - The attacker then proceeded to extract the information disclosed within the s3_buckets.txt file. The file listed URLs to cold and warm storage and internal contact details for clearance – this provided the attacker a map of the company's long-term data structure.

```

220 (vsFTPd 3.0.5)
USER forela-ftp
331 Please specify the password.
PASS ftprock695
230 Login successful.
SYST
215 UNIX Type: L8
FEAT
211-Features:
EPRM
EPSV
MDTM
PASV
REST STREAM
SIZE
TVFS
211 End
EPSV
229 Entering Extended Passive Mode (|||63192|)
LIST
150 Here comes the directory listing.
226 Directory send OK.
EPSV
229 Entering Extended Passive Mode (|||40790|)
NLST
150 Here comes the directory listing.
226 Directory send OK.
TYPE I
200 Switching to Binary mode.
SIZE Maintenance-Notice.pdf
213 27855
EPSV
229 Entering Extended Passive Mode (|||9759|)
RETR Maintenance-Notice.pdf
150 Opening BINARY mode data connection for Maintenance-Notice.pdf (27855 bytes).
226 Transfer complete.
MDTM Maintenance-Notice.pdf
213 20240503034329
SIZE s3_buckets.txt
213 268
EPSV
229 Entering Extended Passive Mode (|||23530|)
RETR s3_buckets.txt
150 Opening BINARY mode data connection for s3_buckets.txt (268 bytes).
226 Transfer complete.
MDTM s3_buckets.txt
213 20240503034852
EPSV
229 Entering Extended Passive Mode (|||15028|)
STOR /home/cyberjunkieXBX/HACKED.txt
550 Permission denied.
QUIT
221 Goodbye.

```

Figure 8 - The image above shows the entire recorded exchange between attacker and server, from when the attacker initially gained access up until they were denied storage by the server due to insufficient permissions.